

Descripción del sistema

Qué hace el sistema: FastFitness es una aplicación web de gestión para un gimnasio en Costa Rica. Permite administrar clientes, membresías, pagos, clases, sesiones, entrenadores, asistencia, máquinas y reportes. La seguridad de acceso depende directamente de las credenciales de SQL Server (no tiene autenticación propia).

Contexto de uso: El sistema se utiliza diariamente desde la recepción del gimnasio para registrar clientes, cobrar membresías y controlar asistencia. También lo usa el administrador de forma remota para consultar reportes. Se ejecuta en un entorno local mediante Docker Compose, expuesto en los puertos 3000 (frontend) y 3100 (backend).

Actores: Administrador del gimnasio: Acceso completo a todas las funciones y Administrador de BD: Configura SQL Server y proporciona credenciales.

Tecnologías

Capa	Tecnología
Frontend	Next.js 15 (React 19, TypeScript, Tailwind CSS, Chart.js)
Backend	Express 5 (Node.js)
Base de datos	Microsoft SQL Server
Contenedores	Docker Compose (puertos 3000 y 3100)
Gestor de paquetes	pnpm

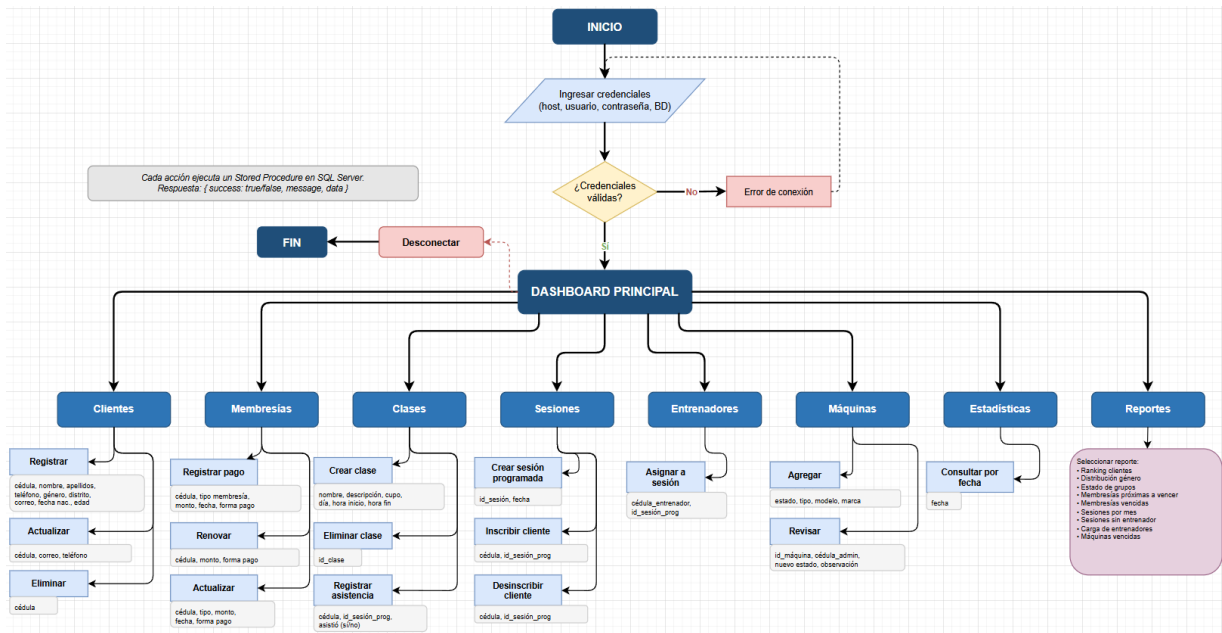
Identificación de activos: *Datos*

Activo	Tipo	Descripción
Datos personales (clientes y entrenadores)	Datos sensibles (PII)	Cédula, nombre, correo, teléfono, fecha de nacimiento, género, distrito
Membresías y pagos	Datos financieros	Tipo de membresía, vigencia, montos, forma de pago
Clases, sesiones e inscripciones	Datos operativos	Oferta de servicios, cupos, horarios, asistencia
Máquinas y revisiones	Datos operativos	Inventario, estado, historial de mantenimiento

Sistemas e Infraestructura

Activo	Tipo	Justificación
API Backend (Express)	Servicio	Punto único de acceso a datos; si cae, el sistema queda inoperativo
Frontend (Next.js)	Interfaz	Única interfaz para operar el sistema
SQL Server	Motor de BD	Activo más crítico: contiene todos los datos y lógica de negocio
Credenciales de SQL Server	Credencial	Único mecanismo de acceso; su compromiso otorga acceso total
dbquery.sql	Artefacto	Script con esquema completo, stored procedures y datos iniciales

Diagrama de flujo de datos de todo el proyecto



Las amenazas y riesgos identificados para todo el proyecto (Threat Modeling)

A-01 — Bypass de autenticación

Campo	Detalle
CAPEC	CAPEC-115 (Authentication Bypass)
Descripción	El backend no implementa ningún mecanismo de autenticación. Todos los endpoints están expuestos sin verificar identidad. Un atacante puede invocar cualquier ruta directamente con curl o Postman sin presentar credenciales.
Activo Afectado	API Backend, datos
Probabilidad	Muy alta
Impacto	Crítico
CIA	confidencialidad, Integridad
Prioridad	Crítica

A-02— Fuerza bruta contra credenciales

Campo	Detalle
CAPEC	CAPEC-49 (Password Brute Forcing)
Descripción	No hay límite de intentos de login, permitiendo ataques automatizados.
Activo Afectado	Credenciales SQL Server
Probabilidad	Alta
Impacto	Crítico
CIA	Confidencialidad

Prioridad	Alta
------------------	------

A-03—Escalación de privilegios por falta de roles

Campo	Detalle
CAPEC	CAPEC-233 (Privilege Escalation)
Descripción	No existe diferenciación de roles ni autorización en ningún endpoint. Cualquier petición tiene los mismos privilegios que el administrador. Un usuario sin autorización puede eliminar clientes, registrar pagos o modificar máquinas con solo conocer la ruta del API.
Activo Afectado	Funciones administrativas
Probabilidad	Muy Alta
Impacto	Crítico
CIA	Confidencialidad, Integridad
Prioridad	Crítica

A-04 — Acceso directo a objetos por referencia (IDOR)

Campo	Detalle
CAPEC	CAPEC-639 (IDOR / Authorization Bypass)
Descripción	Los endpoints permiten consultar datos de cualquier cliente proporcionando su cédula como parámetro URL, sin verificar si el solicitante tiene autorización sobre ese recurso. Un atacante puede enumerar cédulas (000000001 a 999999999) y extraer datos personales masivamente.
Activo afectado	Datos personales
Probabilidad	Alta
Impacto	Alto
CIA	Confidencialidad
Prioridad	Alta

A-05 — Inyección SQL

Campo	Detalle
CAPEC	CAPEC-66 (SQL Injection)
Descripción	El frontend construye parámetros con interpolación de strings, envolviendo valores en comillas simples SQL antes de enviarlos. Además, múltiples controladores no especifican tipo SQL en .input(), debilitando la parametrización. Un atacante puede inyectar sentencias SQL para leer, modificar o eliminar datos.
Activo afectado	Base de datos
Probabilidad	Media-Alta
Impacto	Crítico

CIA	Confidencialidad, Integridad
Prioridad	Crítica

A-06 — Manipulación de parámetros HTTP

Campo	Detalle
CAPEC	CAPEC-178 (Client-side Enforcement Bypass)
Descripción	Las reglas de negocio se validan únicamente en el frontend. Un atacante puede fabricar peticiones HTTP con Burp Suite, inscribiendo clientes sin membresía activa, registrando pagos con montos alterados o cambiando estados no permitidos.
Activo afectado	Pagos, membresías
Probabilidad	Alta
Impacto	Alto
CIA	Integridad
Prioridad	Alta

A-07 — Recolección de información por errores

Campo	Detalle
CAPEC	CAPEC-54 — Query System for Information
Descripción	Los errores del sistema exponen detalles internos como mensajes SQL, estructura de base de datos y código.
Activo afectado	Infraestructura del sistema
Probabilidad	Alta
Impacto	Medio
CIA	Confidencialidad
Prioridad	Media

A-08 — Inyección y envenenamiento de logs

Campo	Detalle
CAPEC	CAPEC-93 (Log Injection)
Descripción	El sistema no posee un sistema de logging estructurado. Los únicos registros son console.log sin formato, sin protección y sin persistencia. Un atacante puede realizar acciones maliciosas sin dejar evidencia, y si inyecta datos con saltos de línea, puede fabricar entradas falsas en los logs de consola para encubrir sus acciones.
Activo afectado	Logs del sistema
Probabilidad	Muy Alta
Impacto	Alto

CIA	Integridad
Prioridad	Alta

A-09 — Eliminación de rastro de auditoría

Campo	Detalle
CAPEC	CAPEC-268 (Audit Log Manipulation)
Descripción	No existe trazabilidad de acciones: no se registra qué usuario realizó qué operación, cuándo, ni con qué resultado. Un atacante que elimine clientes, modifique pagos o acceda a datos sensibles no puede ser identificado ni responsabilizado. La ausencia de auditoría imposibilita la detección de intrusiones y el cumplimiento regulatorio.
Activo afectado	Sistema completo, trazabilidad
Probabilidad	Muy Alta
Impacto	Alto
CIA	Integridad, Confidencialidad
Prioridad	Alta

A-10 — Exposición de credenciales en código fuente

Campo	Detalle
CAPEC	CAPEC-150 (Collect Data from Common Resource Locations)
Descripción	Las credenciales de SQL Server (sa / FastFitness2024!) están hardcodedas en docker-compose.yml y versionadas en el repositorio Git. Además, el frontend transmite credenciales de BD en texto plano vía HTTP al backend. Cualquier persona con acceso al repositorio público o al tráfico de red obtiene acceso total como superadministrador.
Activo afectado	Credenciales de SQL Server
Probabilidad	Muy Alta
Impacto	Crítico
CIA	Confidencialidad
Prioridad	Crítica

A-11 — Acceso directo a SQL Server por puerto expuesto

Campo	Detalle
CAPEC	CAPEC-560 (Use of Known Domain Credentials)
Descripción	El puerto 1433 de SQL Server está mapeado directamente al host, permitiendo conexión desde cualquier máquina en la red sin pasar por la aplicación. Combinado con las credenciales expuestas (A-10), un atacante puede conectarse con SQL Server Management Studio o sqlcmd, ejecutar cualquier consulta, extraer datos completos, modificar registros o destruir la base de datos.
Activo afectado	SQL Server, todos los datos del sistema

Probabilidad	Alta
Impacto	Crítico
CIA	Confidencialidad, Integridad, Disponibilidad.
Prioridad	Crítica

A-12 — Interceptación de datos en tránsito (Man-in-the-Middle)

Campo	Detalle
CAPEC	CAPEC-94 (Adversary-in-the-Middle)
Descripción	Todas las comunicaciones ocurren sin cifrado: el frontend se conecta al backend por HTTP plano, la conexión backend-SQL Server tiene encrypt: false, y CORS está completamente abierto (cors() sin restricción de origen). Un atacante en la misma red puede interceptar credenciales, datos personales y sesiones, además de inyectar peticiones desde cualquier dominio
Activo afectado	Datos en tránsito, API Backend
Probabilidad	Media-Alta
Impacto	Alto
CIA	Confidencialidad
Prioridad	Alta

Las mitigaciones propuestas para las amenazas identificadas

Amenaza/ CAPEC	Mitigación
A-01 Bypass de autenticación CAPEC-115 (Authentication Bypass)	Implementar autenticación con JWT mediante middleware en Express. Cada endpoint debe verificar el token del header Authorization: Bearer <token>. Usar jsonwebtoken con clave en variables de entorno.
A-02 Fuerza bruta contra credenciales- CAPEC-49 (Password Brute Forcing)	Instalar express-rate-limit con máximo 5 intentos/minuto por IP. Bloqueo temporal tras 10 intentos fallidos. Registrar intentos en logs.
A-03 Escalación de privilegio- CAPEC-233 (Privilege Escalation)	Implementar RBAC con middleware authorize(['admin']). Guardar rol en JWT. Crear tabla usuarios con rol y validar en cada ruta.
A-04 Acceso directo a objetos CAPEC-639 Authorization Bypass	Verificar propiedad del recurso: validar que req.user.cedula coincida o que tenga rol autorizado.
A-05 Inyección SQL- CAPEC-66	Eliminar interpolación de strings. Usar parámetros tipados en .input() y stored procedures.

A-06 Manipulación parámetros HTTP -CAPEC-178(Client-side Enforcement Bypass)	Validar reglas de negocio en backend con express-validator o zod.
A-07 Recolección de información por errores - CAPEC-54 — Query System for Information	Middleware de errores con mensajes genéricos. Logs internos con detalle.
A-08 Inyección y envenenamiento de logs -CAPEC-93(Log Injection)	Logging estructurado con winston/pino. Sanitizar entradas y usar archivos rotativos.
A-09 Eliminación de rastro de auditoría CAPEC-268	Crear tabla de auditoría y registrar acciones con middleware.
A-10 Exposición de credenciales -CAPEC-150(Collect Data from Common Resource Locations)	Usar .env, gitignore, usuario BD con mínimos privilegios y rotar contraseñas.
A-11 Acceso directo a BD -CAPEC-560 (Use of Known Domain Credentials)	Eliminar puerto expuesto y restringir acceso a red interna.
A-12 Interceptación de datos (MITM) -CAPEC-94 (Adversary-in-the-Middle)	Habilitar HTTPS, encrypt:true, CORS restringido y headers de seguridad.

El listado detallado de requerimientos de seguridad con el formato visto en clase

ID	Requerimiento de Seguridad (detallado y fundamentado)	Activo	Propiedad	Amenaza CAPEC
RS-01	El sistema debe implementar autenticación obligatoria mediante credenciales únicas y verificarlas en el servidor antes de otorgar acceso, evitando accesos no autenticados a cualquier endpoint protegido.	Sistema / API	Confidencialidad	CAPEC-115 (Authentication Bypass)
RS-02	El sistema debe almacenar las contraseñas utilizando algoritmos de hash criptográfico con sal (ej. bcrypt) y aplicar políticas de complejidad y longitud mínima para mitigar ataques de fuerza bruta.	Credenciales de usuario	Confidencialidad	CAPEC-49(Password Brute Forcing)
RS-03	El sistema debe aplicar control de acceso basado en roles validado en el backend para cada solicitud, impidiendo que usuarios sin privilegios ejecuten funciones administrativas.	Funcionalidades críticas	Confidencialidad	CAPEC-233 (Privilege Escalation)
RS-04	El sistema no debe permitir acceso directo a recursos mediante manipulación de identificadores (IDs), validando que el usuario autenticado tenga permisos sobre cada recurso solicitado.	Datos de clientes	Confidencialidad / Integridad	CAPEC-639 (IDOR / Authorization Bypass)

RS-05	El sistema debe ejecutar todas las consultas a la base de datos mediante consultas parametrizadas con tipos SQL explícitos o procedimientos almacenados, evitando la concatenación o interpolación de entradas del usuario en sentencias SQL.	Base de datos	Integridad, Confidencialidad	CAPEC-66 (SQL Injection)
RS-06	El sistema debe validar, sanitizar y restringir todos los datos de entrada en el servidor, incluyendo longitud, tipo y formato, para prevenir la inyección de código malicioso.	Base de datos	Integridad	CAPEC-152 (Inject Unexpected Items)
RS-07	El sistema debe validar reglas de negocio críticas en el servidor, asegurando que un usuario no pueda inscribirse en sesiones sin membresía activa, ni manipular estados mediante peticiones modificadas.	Membresías / Sesiones	Integridad	CAPEC-178 (Parameter Manipulation)
RS-08	El sistema debe registrar eventos de seguridad en logs protegidos contra modificación, incluyendo intentos fallidos de login y operaciones críticas, para evitar ocultamiento de actividades maliciosas.	Logs	Integridad	CAPEC-93 (Log Manipulation)
RS-09	El sistema debe incluir trazabilidad completa en los logs (usuario, acción, timestamp, resultado) y protegerlos contra acceso no autorizado.	Logs	Integridad / Confidencialidad	CAPEC-268 (Audit Log Manipulation)
RS-10	El sistema debe proteger la transmisión de datos mediante HTTPS/TLS y rechazar conexiones inseguras, evitando la interceptación de información sensible.	Datos en tránsito	Confidencialidad	CAPEC-94 (Man-in-the-Middle)
RS-11	El sistema debe almacenar todas las credenciales y secretos en variables de entorno protegidas, nunca en código fuente ni archivos versionados, evitando la exposición por acceso al repositorio.	Credenciales de SQL Server	Confidencialidad	CAPEC-150 (Collect Data from Common Resource Locations)
RS-12	El sistema no debe exponer puertos de base de datos al host ni a la red externa, limitando el acceso a la red interna de contenedores para impedir conexiones directas no autorizadas.	SQL Server	Disponibilidad, Integridad / Disponibilidad	CAPEC-560 (Use of Known Domain Credentials)

Reflexión final sobre las amenazas y riesgos identificados para el proyecto

El análisis de amenazas sobre FastFitness dejó en evidencia una superficie de ataque bastante expuesta. Las doce amenazas que se identificaron están conectadas entre sí y, si un atacante las explota en cadena, el sistema entero puede caer con poco esfuerzo.

Lo más grave es la falta total de autenticación (A-01). Si el backend no verifica quién está del otro lado, cada endpoint queda completamente abierto: da igual qué tan bien esté diseñada la base de datos si cualquier persona en la red puede consultar, modificar o borrar datos sin identificarse. Esto se vuelve peor con (A-03), porque al no existir roles, quien entra tiene exactamente los mismos privilegios que un administrador.

Después está la exposición de credenciales en el código fuente (A-10) junto con el puerto 1433 abierto al host (A-11). Las credenciales de superadministrador de SQL Server están ahí, visibles en el repositorio, y la base de datos acepta conexiones directas desde cualquier máquina. Un atacante no necesita buscar vulnerabilidades en la aplicación: se conecta con SQL Server Management Studio y tiene acceso total a todo. De las combinaciones analizadas, esta es la que permite un compromiso completo con menor esfuerzo.

Desde la aplicación, A-05 (inyección SQL) y A-04 (IDOR) agravan todo aún más. La interpolación de strings en las consultas permite manipular la base de datos directamente, y la falta de verificación de propiedad sobre los recursos abre la puerta a extraer datos personales de todos los clientes enumerando cédulas. Las dos

vulnerabilidades parten del mismo supuesto erróneo: que solo usuarios legítimos van a interactuar con el sistema, sin considerar que alguien pueda actuar con intención maliciosa.

También preocupa la ausencia de trazabilidad (A-09) y lo débil que es el logging (A-08). Sin registros de auditoría, un atacante puede moverse por el sistema durante semanas sin que nadie lo note, borrando clientes, alterando pagos o accediendo a información sensible sin dejar rastro. Eso hace imposible detectar intrusiones a tiempo, responder adecuadamente ante incidentes y cumplir con normativas como la Ley 8968 de Costa Rica.

Para cerrar, la transmisión sin cifrado (A-12) completa el cuadro. Aunque se corrigieran todas las demás vulnerabilidades, las comunicaciones en HTTP plano permiten que alguien en la misma red intercepte credenciales y datos personales en tiempo real. La apertura total de CORS empeora esto al aceptar solicitudes desde cualquier dominio externo.

Video

<https://youtu.be/xbm2rez-BIk>

Anexos

Bitácora

Reunión 1

Nos reunimos mediante la plataforma meets para las primeras visiones y reparto de tareas según la entrega de la parte 1.

Se eligió un sistema de un gimnasio realizado en un curso anterior. La división de tareas quedó de la siguiente forma:

Responsable	Tareas asignadas
Yeilyn Espinoza	3 requerimientos, 3 amenazas y reflexión
Josue Chaves	Diagrama, 3 requerimientos y 3 amenazas
Jennifer López	Descripción, lista de activos, 3 requerimientos y 3 amenazas
Kimberly Salazar	Mitigaciones, 3 requerimientos y 3 amenazas

Evidencia

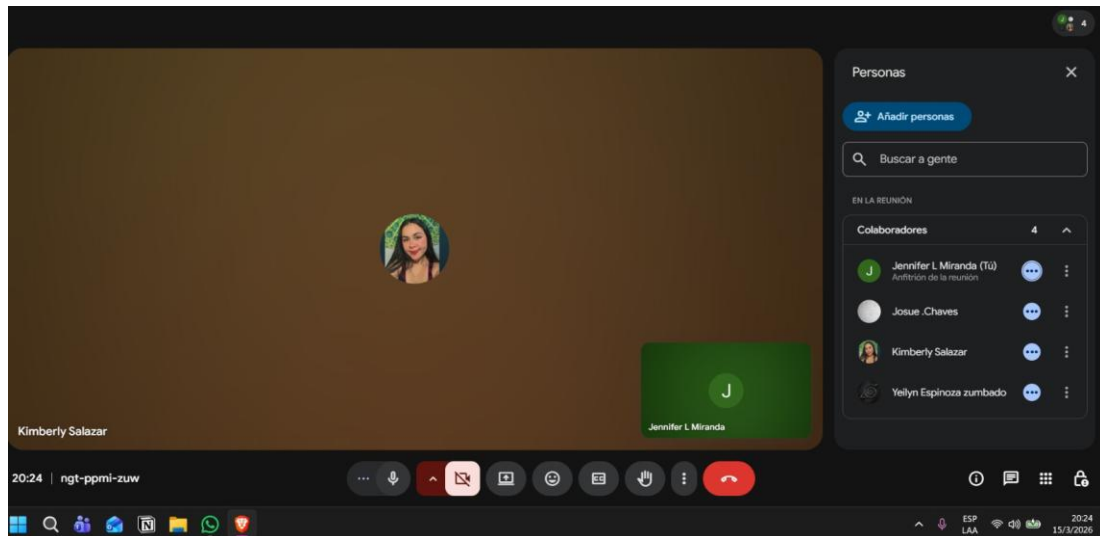


Imagen 1. Evidencia de la primera reunión